

# TESTS.md — Flashordo

لها اختبار يثبت أنها CLAUDE.md اختبارات إلزامية. تُكتب قبل الواجهات. المبدأ: كل قاعدة في القسم 0 من تُرفض عند المخالفة، لا أن تنجح عند الالتزام.

للتدقق Playwright • لمنطق التحقق vitest • للقاعدة pgTAP: الطبقات

## الذرية والتزامن — الأخطر 1)

### T1.1 طلبان متزامنان على آخر وحدة

-- المخزون: صدر دجاج = 1 كغ. كل طلب يستهلك 1 كغ --  
-- في نفس اللحظة confirm\_payment جلستان متوازيتان تستدعيان --

stock = -1. **المتوقع:** طلب واحد ينجح، الآخر يفشل برسالة نقص المخزون. **المرفوض:** نجاح الاثنين، أو

داخل معاملة، سينجح الاثنان. هذا الاختبار هو سبب وجود SELECT ... FOR UPDATE إن لم تستعمل الدالة أصلاً.

### T1.2 الانقطاع في المنتصف

اقتل الاتصال بعد خصم المواد وقبل تحديث حالة الطلب. **المتوقع:** تراجع كامل — المخزون كما كان والطلب **المرفوض:** مخزون منقوص وطلب غير مُمَرَّر. unpaid

### T1.3 «النقر المزدوج على تأكيد الدفع»

(unpaid الحالة لم تعد) مرتين لنفس الطلب. **المتوقع:** الثانية لا تفعل شيئاً confirm\_payment استدع. **المرفوض:** خصم المخزون مرتين.

### T1.4 مادة واحدة ناقصة من ثلاث

طلب يحتاج دجاجاً (متوقّر) وجبناً (متوقّر) وطماطم (ناقصة). **المتوقع:** إجهاض كامل، لا يُخصم الدجاج ولا الجبن، وتُذكر «طماطم» بالاسم. **المرفوض:** خصم جزئي

## الثوابت — قيود القاعدة 2)

|  |  |  |
|--|--|--|
|  |  |  |
|--|--|--|

| #    | المحاولة                           | المتوقع                                               |
|------|------------------------------------|-------------------------------------------------------|
| T2.1 | UPDATE materials SET stock = -1    | CHECK (stock >= 0) رفض بـ                             |
| T2.2 | تمرير طلب يتجاوز المتوقّر          | رفض، والمخزون لم يتغيّر                               |
| T2.3 | حفظ منتج سعره 100 وتكلفة مواده 150 | رفض                                                   |
| T2.4 | حفظ منتج سعره 150 وتكلفته 150      | قبول (التساوي مسموح)                                  |
| T2.5 | دفع 5000 لعامل مستحقّه 3000        | CHECK (paid <= earned) رفض بـ                         |
| T2.6 | رفض طلب غير مدفوع                  | المخزون لم يتغيّر إطلاقاً                             |
| T2.7 | unpaid انقضاء 15 دقيقة على طلب     | المخزون لم يُمسّ ، expired يصير                       |
| T2.8 | تعديل تكلفة مادة بعد بيع منتجات    | التقارير القديمة لا تتغيّر (التكلفة تُجمّد وقت البيع) |

مهمّ: إن قرأت التقارير التكلفة الحالية بدل تكلفة وقت البيع، ستتغيّر أرباح الشهر الماضي كلّما غيّرت T2.8 سعر شراء.

## 3) RLS الصلاحيات و

### T3.1 عزل التجّار

B: materials, products, categories, workers, orders, order\_lines, payments يستدعي كل جدول بمعرف مطعم التاجر A تاجر المتوقّع: صفر صفوف في القراءة، ورفض في الكتابة. المرفوض: أي orders, order\_lines, payments. صفّ يعود.

### T3.2 حساب الموظّفين

orders أو التقارير. المتوقّع: صفر صفوف. يرى workers أو materials يحاول قراءة staff حساب فقط order\_lines و.

### T3.3 التاجر لا يصل للوحة المالك

المتوقّع: رفض. app\_settings لمطاعم أخرى أو يكتب في payments تاجر يستدعي.

### T3.4 ترقية الدور

المتوقّع: رفض. الدور يُغيّر من السيرفر UPDATE profiles SET role = 'admin' مستخدم يحاول لنفسه. فقط.

## T3.5 قراءة الإعدادات

والكتابة مرفوضة، (عامان RIP السعر و) المتوقَّع: نجاح . app\_settings زائر غير مسجَّل يقرأ

## T3.6 حالة الحساب

- status='pending' → دخول لوحة التاجر مرفوض، الرسالة: قيد المراجعة
- status='rejected' → مرفوض، الرسالة: الاشتراك غير مدفوع
- trial\_ends\_at → منقُص → الجلسة تنتهي والبيانات محفوظة

# 4) الأمان

## T4.1 الرفع

| المتوقَّع                           | المدخل                          |
|-------------------------------------|---------------------------------|
| رفض                                 | ملف .svg                        |
| رفض بفحص البايتات الأولى            | payload.html receipt.jpg مسمَّى |
| تُقبل، وإعادة الترميز تُتلف الحمولة | صورة تحوي حمولة مدموسة          |
| UUID يُستبدل بـ                     | اسم ../../etc/passwd.jpg        |
| رفض بحدِّ الحجم                     | 50 MB ملف                       |

## T4.2 الروابط

- ?next=https://evil.com → يُتجاهل، توجيه داخلي فقط
- 403 → رابط وصل الدفع بعد انقضاء مدَّته
- 403 → رابط الوصل من حساب تاجر آخر

## T4.3 الحقن والعرض

المتوقَّع: يُرفض بقائمة المحارف. وإن مرَّ نصًّا، <img src=x onerror=alert(1)> أدخل في اسم مادة غير موجود في dangerouslySetInnerHTML يُعرض كنصّ حرفي بلا تنفيذ. المرفوض: أي تنفيذ. تأكَّد أن المستودع كُله

## T4.4 حدّ المحاولات

مباشرة (لا عبر الواجهة). **المتوقع:** الحظر يعمل على السيرفر. **المرفوض:** API محاولات دخول فاشلة عبر الـ 9. أن يتخطاه تحديث الصفحة

## T4.5 تسريب الأخطاء

اجعل استعلاماً يفشل. **المتوقع:** رسالة موحدة للمستخدم، والتفصيل في سجل السيرفر. **المرفوض:** ظهور اسم Postgres جدول أو عمود أو نص خطأ

## T4.6 تسجيل الخروج

سجل الخروج ثم اضغط زر الرجوع. **المتوقع:** لا بيانات، توجيه لصفحة الدخول، التخزين المحلي فارغ

## T4.7 الوقت

غيّر ساعة الجهاز 5 أيام للأمام في حساب تجريبي. **المتوقع:** التجربة تنتهي حسب وقت السيرفر لا الجهاز

---

## 5) التحقق من المدخلات (جداول)

```
// الأسماء
["بيتزا 30 سم", true], ["كوكا 33 سل", true], ["دقيق", true],
["123", false], ["٥٠٦", false], [" ", false], ["<script>", false], ["'", false]

// الهاتف
["0661234578", true], ["0551088712", true], ["0771902244", true],
["0461234578", false], ["066123457", false], ["06612345789", false],
["066123457a", false], ["+213661234578", false]

// كلمة السر
["abcd1234", true], ["كلمة123سر", true],
["abcdefgh", false], ["12345678", false], ["abc123", false], ["abcd 1234", false]

// مرجع التحويل
["4471203398", true], ["123456789", false], ["12345abcde", false]

// RIP
["007799999002070490038", false /* رقم 21 */, ["00779999900207049003", true]

// الكميات
["0.5", true], ["12", true], ["1.2345", false], ["-1", false], ["1,5", false]
```

---

## 6) الاتساق المحاسبي

بعد يوم كامل من الطلبات، يجب أن تتحقق هذه المعادلات بالضبط:

مخزون البداية - المستهلك في الطلبات المدفوعة = مخزون النهاية  
المبيعات = مجموع إجماليات الطلبات المدفوعة فقط  
الأرباح = المبيعات - تكلفة المواد - الأجور

### T6.1 الطلبات غير المدفوعة لا تدخل

أنشئ 5 طلبات غير مدفوعة. **المتوقع:** المبيعات = 0، الأرباح = 0، المخزون لم يتغير.

### T6.2 المرفوضة والمنتھية لا تدخل

**المتوقع:** لا أثر لها في أي رقم.

### T6.3 الحدود الزمنية

UTC. طلب الساعة 23:59 وطلب 00:01. **المتوقع:** كل واحد في يومه، بتوقيت المطعم لا.

### T6.4 التجديد التراكمي

اشتراك ينتهي بعد 10 أيام، يجدد بباقة شهر. **المتوقع:** النهاية = 10 + 30 = 40 يوماً، لا 30.

---

## 7) التدقق الكامل (Playwright)

### T7.1 المسار السعيد

ولا يظهر في المطبخ → الكاشير يؤكّد → يظهر في المطبخ ويخصم المخزون → unpaid زبون يطلب → الطلب  
المطبخ يسلم → يظهر في تقرير اليوم

### T7.2 المطبخ لا يطبخ قبل الدفع

unpaid. تحقق صراحةً أن شاشة المطبخ فارغة ما دام الطلب

### T7.3 التسجيل المدفوع

تسجيل → قيد المراجعة → الدخول مرفوض → المالك يؤكّد → الدخول ينجح

### T7.4 الرفض

المالك يرفض → الدخول مرفوض برسالة الاشتراك غير المدفوع

### T7.5 منع التكرار

في القاعدة، لا من الواجهة UNIQUE تسجيل بريد مستعمل، ثم بهاتف مستعمل. **المتوقع:** رفض من قيد

## T7.6 التجربة

تسجيل تجريبي → دخول فوري بلا موافقة → بعد 3 أيام تنتهي الجلسة والبيانات محفوظة

---

## فحص يدوي قبل كل إصدار (8)

- (الهاتف، مراجع التحويل، الشعار، RIP، البريد) لا نصّ لاتيني منقلب
  - في كل صفحة flashordo الاسم
  - زر «معاينة اللوحة (عرض تجريبي)» محذوف من صفحة الأدمن
  - لا يعيد شيئاً `grep -r "dangerouslySetInnerHTML"`
  - (ممنوع في الواجهة `service_role`) لا مفاتيح سرّية في كود العميل
  - `SELECT relname FROM pg_class WHERE relrowsecurity = false` — مُفعّلة RLS كل جدول عليه
  - الشعار مقروء عند 32 بكسل
  - الواجهة تعمل بلا اتصال: رسالة الشبكة تظهر ولا يظنّ المستخدم أن كلمة سره خاطئة
- 

## التشغيل (9)

```
pnpm test:db      # الأقسام 1، 2، 3 — pgTAP
pnpm test:unit    # القسم 5 — vitest
pnpm test:e2e     # الأقسام 4، 6، 7 — Playwright
```

شرط الدمج: الأقسام 1، 2، 3 خضراء بالكامل. لا استثناء